SOC Tier 2 Incident Analysis

AutoLMS webshell compromise on bom stg all2

Prepared 28 October 2026 | Version 1.0 | Intended recipients SOC lead and incident response team

Executive assessment

Disposition: True positive compromise. Recommended severity: Critical. Operational status: partially contained at the last recorded update on 24 October 2026 at approximately 18:30 ICT (UTC+07). The incident should remain open pending current validation.

The reported evidence supports compromise of the FTU AutoLMS application, execution under the web service account, and deployment of backdoors across nine sites on bom-stg-all2. Exposed credentials and reported access to three additional servers create a wider incident requiring coordinated containment. Cleanup of the staging web roots does not establish that organizational access has been removed. [S1 pp 1-4, 29-33]

Incident attribute	Assessment
Primary asset	bom-stg-all2, internal IP 10.0.10.128, behind reverse proxy 103.252.72.136
Category	Web application exploitation, webshell persistence, credential exposure and reported lateral movement
Observed activity window	14-23 October 2026; approximately ten calendar days in the source report
Affected websites	bav, haui, nau, qbu, tmu, ftu, dhv26, inu26 and tvu26
Evidence confidence	High for the reported staging compromise; moderate for summary-dependent lateral movement and data access
Response ownership	SOC lead to assign an incident commander and named infrastructure, application, identity and legal owners

Decisions required

Activate a coordinated response covering staging, the three reportedly accessed servers and systems that accept exposed credentials. Isolate affected assets and revoke credentials in parallel, preserving evidence where practicable. Escalate primary evidence acquisition to DFIR or SOC Tier 3 and notify production owners through the incident commander.

Do not authorize unrestricted return to service until the application defects are repaired, trusted recovery is complete, and credential and session revocation is verified. New credentials must be provisioned through trusted administrative systems.

Severity rationale: multi-site code execution, access to authentication material, reported privileged access to additional systems, and possible personal-data exposure. Business outage duration, affected record count and financial loss remain unquantified. [S1 pp 1-2, 26-30]

Evidence confidence and affected scope

Confidence describes the strength of the reported evidence for each claim. High means multiple specific observations are described; moderate means the claim depends on a prior summary or incomplete corroboration; unresolved means available findings do not establish the outcome. These labels do not certify host cleanliness.

Finding	Confidence and basis	Required corroboration
FTU entry and nine infected sites	High. Application logic, HTTP sequence and file metadata support the reconstruction. [S1 pp 2-5, 25]	Original access logs, deployed source version and acquired malware samples.
108 private-key files collected	High for reported file presence. Names suggest CI-related material; origin and unique key count are unresolved. [S1 pp 10, 12]	Fingerprint inventory, duplicates, key owners and accepting systems.
SSH access to three servers	Moderate. Marked verified in the source, but supported by prior chat memory summaries labelled MEM. [S1 pp 1-3, 26]	Destination authentication and sudo logs, key fingerprints and host evidence.
HAUI dump and secrets read	Moderate. Reported in MEM summaries. External transfer is unresolved. [S1 pp 1, 12-13, 26]	Preserved command evidence, network records, database audit and access logs.
GitLab or production compromise	Unresolved. Exposed token material and production key names create a credible exposure path. [S1 pp 12, 25-26]	GitLab audit, runner and repository history; production host and application logs.
External MySQL and Airflow access	Unresolved. Database login attempts and Airflow tooling are reported. [S1 pp 10, 13, 26]	Service authentication records and investigation of af_win.ck in isolation.
Root compromise on staging	Not established. Checks found no evidence; file ownership and negative scans do not rule it out. [S1 pp 11, 14, 32]	Trusted host acquisition, administrative audit and DFIR review.

Scope to retain

Include all co-hosted sites, the 16 api-* virtual hosts, gp26, staff-lms, and every system accepting keys or secrets accessible to www-data. Absence of the known loader on a site does not exclude data access or another backdoor. Treat the proxy as an investigation target, not a confirmed compromised host. [S1 pp 1, 14-15, 24-26]

Reported SSH destinations: root@103.252.72.221, root@103.252.73.52 and dev01@103.252.73.238 with sudo. Exposure assessment also includes MySQL at 27.71.21.34 and 27.71.21.176:63306, GitLab and CI/CD, Airflow, and DNU/NAU production nodes.

Incident timeline and entry analysis

All times below are ICT (UTC+07). Preserve original timestamps and offsets when collecting evidence. Older compressed nginx logs use UTC; current logs and .1 use ICT according to the source. The earliest observed success is not proof of the first possible compromise. [S1 pp 1-4]

Time in October 2026	Event	Interpretation
12 Oct 17:09-17:13	Reported ownership change placed about 205,000 files under www-data.	Pre-existing exposure that enabled cross-site writes; MEM-dependent.
13 Oct 23:32-23:42	Probes against set_login and osp/import from 61.124.1.29.	Reported rejected responses; response length alone is insufficient to prove outcome.
14 Oct 00:18:43	FTU login and import responses differed from failed attempts.	Session acquisition supported by the later upload and malware sequence.
14 Oct 00:19-00:20:51	ft9.php uploaded and requested 64 times.	Consistent with interactive or automated use; request logs do not reveal all commands.
14 Oct 00:20:09-00:20:51	Nine loader and payload pairs created; modification times backdated.	Rapid deployment supports automation. Minor second-level differences exist in source tables.
14 Oct 15:46	Key collection directory .glyph created with 108 private-key files.	Establish key provenance and all accepting systems.
14-23 Oct	Reported secret access, SSH scanning and access to three servers.	Corroborate MEM claims with destination and network records.
23 Oct 16:08-16:17	60 POST requests to the FTU loader returned HTTP 200.	Last explicitly cited loader activity; a separate account of activity to 20:18 is unresolved.
23 Oct about 22:11 onward	Evidence collection and nginx containment; further controls applied on 24 Oct.	Containment was incremental. Later changes require their own validation timestamps.

Entry mechanism

The reported chain is forged AutoLMS authentication followed by unrestricted upload and PHP execution. set_login trusted a base64 and JSON cookie containing identity and role fields without a signature. The import handler accepted any file type and wrote into a web-accessible directory where PHP could run. Base64 encoding provides no authenticity. [S1 pp 2, 25]

Shared www-data execution and writable application trees expanded the impact from FTU to other sites. Readable secrets and unrestricted network access then enabled credential use and movement beyond the original host. No specific CVE or threat actor is established.

Webshell behavior and attack mapping

The persistent backdoor used a small PHP loader plus disguised companion content. The initial ft9.php sample is absent; its role is reconstructed from the request sequence and subsequent file creation. [S1 pp 4-10]

Layer	Reported behavior
Initial entry file	ft9.php in the FTU AutoLMS upload directory reportedly executed commands and installed the nine persistent pairs before deletion.
Loader	plg_cache_<id>.php, approximately 1 KB, used a fake Joomla plugin header and ROT13-obfuscated function names. It decoded a companion payload into a temporary file, included it through PHP and deleted the temporary file.
Payload	Files disguised as fonts, images, cache or session data implemented file listing, reading, writing, deletion, timestamp changes, system commands and host information collection. Several were 2,566 bytes.
Access and concealment	Payload authentication reportedly varied by date and domain. Commands travelled in POST bodies absent from the described access logs. Backdated timestamps and separated loader and payload content reduced visibility.

Companion extensions such as .jpg or .woff2 do not establish safe content. Auxiliary bypass_df*.so files and Python tools were found separately; their presence does not prove every loader used them or that a bypass succeeded. Malware family, full protocol and cryptographic implementation remain unassigned.

MITRE ATTACK mapping

Mappings describe reported behavior and inherit the evidence confidence above. They do not identify an actor. Technique definitions were checked against MITRE. [S2]

Technique	Case behavior	Evidence strength
T1190 Public application exploitation	AutoLMS authentication and upload defects.	High
T1505.003 Web Shell	Nine PHP loader and payload pairs.	High
T1552.004 Private Keys	108 private-key files in .glyph.	High for presence
T1021.004 SSH	Reported login to three additional servers.	Moderate MEM
T1070.006 Timestomp	Backdated modification times.	High
T1005 Data from Local System	Reported reading of HAUI dump and configuration data.	Moderate MEM

No exfiltration technique is assigned: external transfer of the HAUI dump is not established. Root access on other hosts must not be described as demonstrated privilege escalation on staging.

Indicators and evidence preservation

Indicators below are reported historical observables. Validate context before enforcement; filenames, user agents and shared IP infrastructure are not sufficient for attribution. Domain text is defanged to prevent accidental navigation. [S1 pp 3-11, 31]

Type	Observable	SOC use
Reported control infrastructure	d[.]zzkefa[.]com; 180.93.160.36; HTTP 80 /data/ and HTTPS 31443.	Hunt DNS, proxy, firewall and host connections. Do not contact the infrastructure.
Reported source IPs	61.124.1.29; 180.93.160.36; 103.76.182.40; 158.247.235.77.	Correlate activity with paths, timing and trusted client-IP fields. The last address is reported probing TMU.
Unresolved IP	49.51.33.159 requesting /local/hd72/index.php.	Investigate separately; relationship to this incident is unconfirmed.
Loader and initial file	plg_cache_<8-character id>.php; ft9.php. FTU example plg_cache_uxi8sv56.php.	Search web roots, file history and HTTP logs; review content and creation events.
Payload names	font_*.woff2, cache_*.bin, img_*.jpg, sess_*.log, idx_*.dat. INU26 example sess_ahmxcasd.log.	Correlate suffixes to loader names. Extensions and reported size are supporting clues only.
Tool and key locations	/var/tmp/.syslibs/ and /var/www/haui/autolms/application/cache/.glyph.	Acquire and hash before approved cleanup; restrict access to key-bearing evidence.
Exploited endpoints	/autolms/index.php/login/login/set_login and /autolms/index.php/autocourse/osp/import.	Correlate login, upload and subsequent PHP execution across every route and alias.
User agents	curl/8.14.1 and curl/8.0.	Low-specificity enrichment only; normal administrators may use curl.

Preservation requirements

Preserve the source IR directory /root/ir/20261023-2211/ and all later additions. Collect available host snapshots, process and connection records, logs, malware archives, deployed code and configuration, plus off-host service records. Record collector, UTC time, source, acquisition method, SHA-256, transfer history and access controls. Store a protected master copy and analyze working copies.

Reconcile the SHA256SUMS manifest and confirm off-host copies of later artifacts. Some original loaders were deleted before packaging; existing hash checks cannot restore those samples or establish completeness. glyph.tgz contains private keys and needs restricted, encrypted handling. Do not execute recovered code on production or publish secrets in the case record. [S1 pp 15-16, 30-33]

Containment review and urgent response

Recorded staging controls reduced exposure, but coverage and persistence remain incomplete. Status below reflects the source cutoff, not a current validation. [S1 pp 15-25, 29-33]

Control	Recorded status	Remaining validation
nginx blocks	Known entry routes blocked on 11 bom vhosts plus staff-lms.	Assess 16 api-* vhosts and gp26; test external and internal routing and aliases.
Code permissions	Ownership changed on 11 sites; NAU write denial tested.	Check effective writes, parent directories, groups and ACLs; ownership counts alone are insufficient.
Outbound filtering	www-data IPv4 restriction tested; internal 10/8 and DNS permitted.	Validate IPv6, internal access, DNS, rule order, active sessions and persistence after restart.
PHP and monitoring	Configuration checks passed; cron monitor created.	Verify actual FPM runtime and monitor execution. PHP restrictions are supplementary controls. [S4]
Malware removal	17 of 18 persistent loader/payload artifacts reported removed.	Resolve remaining INU26 payload and .glyph status; hunt beyond known names.

Immediate response priorities

The incident commander should run the following workstreams in parallel. Time targets begin when the current response is activated and are proposed priorities, not agreed service commitments.

Priority and proposed owner	Action	Acceptance evidence
P0 now IR lead and infrastructure	Isolate staging and the three reportedly accessed hosts with controlled management access. Preserve evidence without delaying essential containment.	Network isolation verified from a trusted vantage; asset list and exceptions recorded.
P0 now Identity and GitLab owners	Inventory key fingerprints and revoke exposed keys, git/deploy/runner tokens and other affected credentials at their issuing systems.	Revocation records and controlled tests show old credentials rejected across the mapped scope.
P0 now Application and production owners	Keep vulnerable routes disabled; assess production equivalents, invalidate affected sessions and contain exposed service accounts.	Endpoint coverage, session invalidation and production owner acknowledgement recorded.
P0 now SOC and legal lead	Preserve central logs, open a coordinated case and initiate personal-data impact and notification review.	Evidence register, named owners and time-stamped escalation decisions.

Deliver replacement secrets only to trusted systems. Credential rotation on a host still under attacker control can expose the replacement. Revoke active sessions and investigate existing authenticated connections as well as future login attempts.

Tier 2 investigation and detection plan

Begin the hunt before 13 October and continue through the present, subject to retention. Retain event time, ingestion time, timezone, asset identity and trusted proxy metadata. Missing logs or zero matches must be reported as coverage limits, not evidence of absence.

Investigation question	Evidence and correlation	Escalation trigger
Did the web entry affect other sites	Correlate set_login and import requests with later PHP access, FPM child processes and file creation. Include api-* and alternate upload handlers.	New execution or writes outside the known nine sites.
Which credentials were used	Join key fingerprints and destination Accepted publickey records to account, source, session and sudo events. Include NAT mappings and all credential-bearing hosts.	Successful use of an exposed credential or privileged activity without an approved change.
Was CI or production altered	Review token usage, deploy keys, runners, variables, pipelines, webhooks, branches, commits, packages and deployed releases.	Unauthorized configuration, pipeline or code changes; unsafe deployment source.
Was data read or transferred	Correlate dump and secret access with process, database, proxy and network telemetry. Review outbound volumes and archived attacker command evidence where available.	Evidence of unauthorized sensitive-data access or transfer; immediate legal reassessment.
Are there other persistence paths	Review Moodle admins and roles, sessions, config_log, tasks and pathto settings; OS services, scheduled jobs, SSH keys, containers and Git hooks.	Unauthorized account, task, hook, service or configuration.
What do the proxy hits represent	Resolve the 102 requests recorded as 103.252.72.136 using proxy request IDs and trusted forwarding data. Validate the proxy trust boundary.	Internal origin or further compromised client; inconsistent client-IP reconstruction.
Are suspicious changes legitimate	Compare config.php, built JavaScript and onschoolliveclass against independent trusted builds and change records.	Unexplained change, injected client code or unsigned-off plugin installation.

Detection requirements

- Alert on a correlated login or import sequence followed by new server-side files, FPM execution or suspicious child processes. Do not rely on response length or HTTP 200 alone.
- Alert on new PHP or unexpected executable content in writable directories, reappearance of loader/payload patterns, and new code write access for a service account.
- Alert on use of revoked keys or tokens, unexplained privileged sessions, control-infrastructure connections, and new outbound destinations from web workers.
- Send security logs to protected off-host storage. Add legitimate deployment context, test detections with controlled events, and record event coverage and alert results.

Escalate to DFIR or SOC Tier 3 for host integrity, recovered malware behavior, uncertain privilege level and possible data transfer. Preserve live evidence before termination where feasible; urgent containment takes precedence over perfect collection.

Recovery requirements and closure decision

Recovery should establish trust in the host, application and identity systems. The preferred path is a clean build from independently validated sources, with vulnerable functionality repaired before exposure. A documented exception requires explicit risk ownership and compensating controls; it does not establish forensic cleanliness. [S1 pp 28-30; S3]

Required recovery work

- Rebuild affected hosts from trusted images. Validate deployment sources and CI/CD before restoring application code, configuration or data. Do not copy unknown scripts, hooks or scheduled tasks into the replacement.
- Replace the cookie trust mechanism with reviewed authentication and server-side authorization. Do not accept a client-supplied role as authority. Retest expiry, replay resistance, logout and session revocation.
- Restrict uploads to required formats, validate content and size, generate safe filenames and store outside the web root where feasible. Prevent script execution in writable locations. Review every equivalent upload handler. [S5]
- Separate site service identities and limit filesystem and network access to actual dependencies. Check effective permissions across files and parent directories. Validate IPv4, IPv6, DNS and internal network restrictions.
- Rotate exposed secrets, invalidate sessions, review administrative accounts and verify that replacement credentials were never provisioned to an untrusted host. Complete user and privacy actions based on the data assessment.

Evidence required before closure

Closure requirement	Acceptance record
Scope resolved	All named assets and credential recipients assessed; any remaining unknown has an owner and accepted risk decision.
Access removed	Revocation confirmed at issuers and accepting systems; old keys, tokens and sessions fail controlled checks.
Trusted recovery	Clean build records, trusted deployment provenance, application remediation tests and business acceptance for each recovered service.
Persistence addressed	Host, application, database and identity findings resolved; residual INU26 payload and .glyph status explicitly recorded.
Monitoring validated	Off-host telemetry and detections tested. A defined observation period shows no unexplained successful access, new persistence or control traffic.
Governance complete	Data-impact and notification decisions recorded; evidence retained; incident commander and service owners sign off.

Seven days can be proposed as an observation period after recovery, subject to the incident commander. The source requirement for no blocked HTTP 403 probes should be removed: blocked attempts can continue while controls work. Use successful unauthorized activity, unresolved alerts and telemetry completeness to judge recovery.

Tier 2 recommendation: retain Critical severity until exposure is bounded and active access is removed. Downgrade or closure requires new evidence. No current-state assurance can be inferred from a 24 October checkpoint alone.

Handover and reference register

Operational handover

The next shift should receive the current asset list, evidence register, active containment changes, credential revocation tracker, unresolved findings and named owners. Record both confirmed compromise and exposure-only assets. Escalate immediately for any newly successful access, persistence, sensitive-data transfer or loss of monitoring.

Track progress through counts of assets isolated and assessed, exposed credentials mapped and revoked, sessions invalidated, unresolved high-risk findings and recovery tests completed. Record the denominator and supporting evidence for every completion metric. Avoid percentage claims when scope is still changing.

Personal data and legal review

The HAUI dump is reported read; record types, number of affected people, password representation and external transfer remain unresolved. Preserve that distinction in customer and management communications. The legal owner should determine applicable notification duties without waiting for perfect exfiltration evidence.

The source cites Decree 13/2023 for an October 2026 event. Update that reference: Law 91/2025/QH15 and Decree 356/2025 form the 2026 framework, and Decree 13 ceased to apply from 1 January 2026. Current Ministry of Public Security guidance describes a conditional 72-hour notification obligation under Article 23 and the process under Article 28. Counsel must determine applicability, the relevant discovery time, recipients and any overdue response. [S6]

References

[S1] Source incident report, bao-cao-su-co-bom-stg-all3.pdf, 33 pages; report title identifies bom-stg-all2; version 24 October 2026, approximately 18:30 ICT. Page numbers in this analysis refer to PDF page order. The all3 file label is not evidence of a separate affected host.

Source PDF SHA-256: 11d4023b228663e095ec640a039f219c68a96d210a0f6d1ea036b97a0655eec9

[S2] MITRE ATT&CK technique definitions, accessed 28 October 2026. Mapping is analyst assessment of reported behavior.

https://attack.mitre.org/techniques/T1190/
https://attack.mitre.org/techniques/T1505/003/
https://attack.mitre.org/techniques/T1552/004/
https://attack.mitre.org/techniques/T1021/004/
https://attack.mitre.org/techniques/T1070/006/
https://attack.mitre.org/techniques/T1005/

[S3] NIST SP 800-61 Rev. 3, April 2025. Incident response reference; no claim of organizational conformance.

https://csrc.nist.gov/pubs/sp/800/61/r3/final

[S4] PHP Manual, core php.ini directives. Limitations of disable_functions and open_basedir.
https://www.php.net/manual/en/ini.core.php

[S5] OWASP File Upload Cheat Sheet.
https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html

[S6] Government and Ministry of Public Security explanations of the 2026 data-protection framework, accessed 28 October 2026.

https://dbnd.daklak.gov.vn/bao-ve-du-lieu-ca-nhan-khi-so-hoa-ho-so-cong-chuc-5891.html

https://mps.gov.vn/chinh-sach-phap-luat/bai-viet/canh-bao-nguy-co-vi-pham-phap-luat-ve-an-ninh-mang-doi-voi-doanh-nghiep-ho-kinh-doanh-trong-qua-trinh-chuyen-doi-so-1785806444